〔NEXUS WORK 조 회의록 및 활동일지〕 2026.11.03(화)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-11-03(화), 개별 작업 + Notion 작업 보고서 공유
· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· 팀원 질의(R8/디코이 오라벨링 의혹, 태빈님 수정 pptx 검토 등)에 실제로 답하고, 격차가 있으면 Graylog·n8n까지 직접 고쳐서 "걸리면 알림 가고 막을 수 있게" 완성
· 11/6(금) 본발표 대비 pfSense 운영 환경 실측 점검, 발표 대본·회고록 정비
· "인시던트 티켓" 데모 역할 분담 재검토(진혜정=n8n/R2, 홍주형=디코이, 태빈=R8, 시헌=pfSense) 가능 여부 확인

■ 조원별 활동 내역

▶ 진혜정 (R8 디코이 오라벨링 + R9/R10 공백 수정·검증)

· R2~R10까지 소스코드·Graylog 쿼리·n8n 분기 조건을 하나씩 대조해, 디코이 허니팟(event_type=decoy_triggered)이 공식 R8(event_type=not_found, 60초 집계)과 전혀 다른 이벤트라서 티켓이 안 걸리던 오라벨링 문제를 확인
· /hr/cards IDOR 거부(reason=out_of_scope, resource=hr_card:N)가 R9(required=admin)·R10(resource=payroll:*) 어디에도 안 걸리는 공백도 발견
· Graylog에 DECOY Event Definition 신설 + R10 쿼리를 resource:(payroll:* OR hr_card:*)로 확장, n8n workflow(정규화 코드 노드)에 DECOY 규칙(rules/severity/evidence/decision 체크) 추가 — R5/R6/R8 자동차단 gate에는 넣지 않아 앱의 기존 즉시 차단과 중복 안 되게 처리
· 문서 3종(N8N_RULE_MATRIX.md, SECURITY_LOG_SPEC.md, N8N_HANDOFF.md) 갱신, 샘플 payload 2개 추가, 수정한 n8n workflow json을 바탕화면에 전달
· mock이 아니라 Docker로 MySQL을 직접 띄워 앱을 로컬 실행 → /.env, /hr/cards/〈타인id〉를 실제로 호출해 로그 이벤트가 오늘 고친 Graylog/n8n 조건과 필드 값까지 정확히 일치하는 것을 확인 (기존 hr 테스트 51개 중 50개 통과, 실패 1건은 무관한 기존 grants.sql 버그로 별도 발견·보고)
· "인시던트 티켓" 데모 새 역할 분담안을 md로 정리해 팀에 공유, 실제 존재하는 CLI 경로(/internal/api/v1/blocked-ips, logs/security.jsonl tail, PowerShell Graylog 검색)로 정확한 시연 코드 보강, Graylog Events API·n8n 실행조회 API가 레포에 없다는 점은 추측하지 않고 명시
· NEXUS_AI-XDR_하이브리드_관제_기획안.md에 평문 토큰이 박혀있는 것을 발견해 보안 플래그로 남김

▶ 홍주형 (코어 아키텍처·발표 대본)

· 팀 40장 통합 발표자료 구조 분석, 본인 담당(앱·DB 하드닝, 슬라이드 20~29번) 확정
· "방어 모드 ON/OFF"가 화면 눈속임이 아니라 실제 서버 메모리(current_app.config)·.env를 조작하는 진짜 런타임 스위치임을 코드(app/security.py, app/admin.py, app/chat.py)로 직접 검증 — 반면 R9(관리자 권한)·R10(IDOR)·전자결재(BOLA)는 토글과 무관하게 절대 꺼지지 않는 고정 방어선임을 확인

· 공식 7단계 발표 가이드라인에 100% 맞춘 발표 대본 완성(라이브 시연 동선, 예상 Q&A 3선 포함), 보안 용어를 일상 비유로 정리
· 고화질 PDF·HTML 발표자료 생성해 4개 경로에 배포

▶ 이시헌 (pfSense 운영 환경 실측 점검)

· 내일 시연 녹화 전, pfSense 서비스 11개 전부 정상 가동 확인(Status → Services)
· HAProxy portal_backend Server timeout이 이전에 수정한 90초로 유지되고 있는 것, 504 재발 없이 정상 중계 중인 것을 Stats 페이지에서 직접 확인
· Suricata가 설계대로 탐지 전용(Blocking Mode DISABLED) 상태로 정상 가동 중임을 확인(차단은 n8n/XDR 자동화가 전담)
· 방화벽 룰(GeoBlock, XDR_BLOCKED_IPS, NEXUS_AUTO_BLOCK, 포털 5070 허용, Kali NAT 경로 등)이 전부 살아있는 것 확인, pfBlockerNG 대시보드 빈 화면은 UI 표시 이슈일 뿐 기능엔 영향 없음으로 판단
· 결론: 의도적으로 꺼둔 기능 제외하고 전부 정상 작동, 내일 녹화 진행에 지장 없음

▶ 김태빈 (Graylog R8 주기 조정·n8n 후보 비교)

· R2와 R8을 짧은 간격으로 발생시켜 Graylog Alerts에서 두 경보가 모두 보이는 것을 확인, 변경 전 실행 주기 차이(R8 1분·R2 15초)로 화면 표시 시점이 달라질 수 있음을 확인
· 시연 때 R8 경보가 늦게 뜨는 시간을 줄이기 위해 운영 Graylog R8 Event Definition의 Execute every를 1분에서 30초로 변경(검색 조건·임계값·Grace Period는 유지)
· 진혜정이 전달한 n8n 후보 파일(decoy-r10-fix-candidate.json)을 기존 버전과 비교 — Ticket ID를 numeric DB ID로 연결하는 JOIN 변경, Discord 메시지 서식 변경이 포함돼 있고 decoy 이벤트 분기는 R10과 별도 경로임을 확인했으나, Code 노드 2개의 실행 모드 설정 누락과 비활성 계정 조치 노드 연결 차이도 발견
· n8n 화면 연결이 끊겨 운영 Published workflow와의 최종 대조·Import는 하지 못함(미완료로 명시)

■ 조원별 의견 및 제안 사항

· 진혜정: "R8이 서버 코드에서 걸리는 거라 티켓이 아니다"라는 팀 의견을 계기로 R2~R10을 전부 재검증한 결과 디코이만 진짜 공백이었고, R2는 구조상 정상이라는 걸 구분해서 알려야 한다고 판단
· 김태빈: R8 주기를 30초로 줄이면 1분 검색 창과 겹쳐 중복 집계 가능성이 있어, 실제 이벤트로 지연·중복 여부를 반드시 재검증해야 한다는 점을 공유
· 이시헌: 화면상 빈 UI(pfBlockerNG 대시보드)만 보고 장애로 오판하지 않도록, 실제 서비스 상태(Status 페이지)까지 교차 확인하는 습관이 중요하다고 제안

■ 회의 결과 및 결정 사항

1. Graylog DECOY Event Definition 신설 + R10 쿼리 확장(resource:(payroll:* OR hr_card:*))을 확정, n8n 정규화 코드에 DECOY 규칙 추가한 workflow json을 김태빈에게 전달
2. 운영 Graylog R8 Event Definition의 Execute every를 1분→30초로 변경(김태빈) — 단, 실제 지연·중복 검증은 아직 미완료라 운영 반영 여부는 보류
3. "인시던트 티켓" 데모 새 역할 분담(진혜정=n8n/R2, 홍주형=디코이, 태빈=R8, 시헌=pfSense)은 기존 11/2 가이드·확정 speaker_notes와 달라 팀 확정 전까지 보류, on/off 토글 없이 흐름만 보여주는 방식으로 합의

4. pfSense 운영 환경은 내일 시연 녹화 진행에 지장 없는 상태로 확인 완료(이시헌)

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황
  · DECOY/R10 fix를 Graylog·n8n 양쪽에 실제로 반영하고 로컬 실측까지 검증 완료, 태빈님께 workflow json 전달(진혜정)
  · 발표 대본 7단계 가이드라인 100% 매핑 완성, 방어 모드 토글의 아키텍처 본질을 코드로 검증(홍주형)
  · pfSense 서비스 11개 전부 정상 가동, HAProxy 수정 유지·Suricata·방화벽 룰 전수 확인 완료(이시헌)
  · Graylog R8 주기 조정 시도, n8n 후보 파일 비교까지 진행(김태빈)
· 어려운 점

1. 김태빈님이 n8n 화면 연결이 끊겨 전달받은 workflow json을 운영 Published workflow에 아직 Import/Publish하지 못함 — "인시던트 티켓" 데모 중 n8n 확인 파트 리허설이 당장은 불가능한 상태
2. R8 Event Definition 주기를 30초로 줄인 효과(지연 감소)와 부작용(중복 집계 가능성)을 아직 실측 검증하지 못해 운영 반영 여부가 불확실함
3. "인시던트 티켓" 데모 역할 분담이 기존에 확정된 자료(11/2 4티켓 가이드, speaker_notes)와 겹치거나 달라 팀 전체 확정이 필요함
4. NEXUS_AI-XDR_하이브리드_관제_기획안.md에 평문 토큰이 노출된 것이 발견돼 실제 운영 토큰인지 확인·조치가 필요함(미해결)

■ 향후 활동 계획 및 역할 분담

· 김태빈: n8n 화면 재접속 후 전달받은 workflow json을 Published에 반영하고, R8 주기 변경분(30초)의 지연·중복 여부 실측 검증
· 역할 분담(R1·R9+R10을 누가 다루는지, on/off 토글 제외 여부)을 팀 전체가 확정
· 태빈님이 수정한 pptx의 footer 페이지 숫자("13/38") 버그 수정 여부 확인(진혜정)
· NEXUS_AI-XDR_하이브리드_관제_기획안.md 토큰 노출 건 팀 확인·조치
· 11/5(화) 리허설 — 통합 발표자료·개인 대본 기준 실전 타이머 리허설(전체)

■ 증거 자료

· 노션 '회의 및 작업내용'(11/3 페이지): 진혜정 - 11/03 작업 / 2026-11-03_홍주형_엔지니어링_작업회고록 / 11/03 작업 보고서(이시헌) / 2026-11-03 작업 기록(김태빈, 개인 워크스페이스)
· 로컬 파일: nexus-alert-v3-decoy-r10-fix-candidate.json(바탕화면 전달분), event_definitions.json, N8N_RULE_MATRIX.md/SECURITY_LOG_SPEC.md/N8N_HANDOFF.md